

Technické mezery a rizika

Stav zdrojového kódu · commit 6792f0c256e81e1473908308bd73881004853be4 (master, 22. 9. 2026)

Slovník: úklidník = „Zhotovitel“ (VOP, RS, RŘ, Kodex) = Employee (kód) = „uklízeč“ (UI); zákazník = „Zákazník / Spotřebitel / Uživatel“ = User; host = zákazník bez účtu (Order.UserId = null); provozní společnost = „Provozovatel / Cleansia s.r.o.“ = Tenant; administrátor = Administrator / Manager / Support / Accountant.

Závažnost: **kritická** = ztráta peněz, porušení právní povinnosti nebo únik údajů jiné osoby možné dnes; **vysoká** = totéž v reálném scénáři vyžadujícím rozhodnutí; **střední** = chybné chování, malá oprava; **nízká** = hygiena, mrtvý kód.

Deset mezer

#	mezera	proč	závažnost	citace	→ Rn
1	CalculateOrderPackageHandler include jen SelectedServices, čte SelectedPackage s prázdné — balíček bez odměny	úklidník na balíčkové zakázce nedostane balíčkovou sazbu	kritická	CalculateOrderPackage.cs:117-120; CalculateOrderPackage.cs:139-140	Include(Selected Packages) v CalculateOrderPackage
2	Adresa je řádek deduplikovaný na Street, City, ZipCode, CountryId; CustomerAddress. Anonymize() při výmazu i sweepu jej přepíše sousedům	poškození údajů jiných zákazníků	kritická	AddressRepository.cs:9-16; GdprDeletionService.cs:393-396	adresa per zákazník
3	ResolveDispute ignoruje selhání refund: spor je Resolved s RefundAmount, peníze neodešly, příkaz vrací úspěch	zákazník bez peněz, rozhodnutí vypadá vykonaně	kritická	ResolveDispute.cs:77-81	selhání refundu jako chyba příkazu

#	mezera	proč	závažnost	citace	→ Rn
4	Doklad: řádky jen SelectedServices / SelectedPackages , sleva a ApplyExpressSurcharge bez řádku; hotovostní doklad Payment Status: Pending	součet řádků ≠ Total ; hotovost bez dokladu o zaplacení	vysoká	ReceiptService.cs: 395-404; ReceiptService.cs: 410	→ R1
5	Právní texty s bannerem Návrh – toto znění zatím neprošlo právní kontrolou zapisuje LegalDocumentSeedHostedService při každém startu v každém prostředí	souhlasy a přijetí se vážou k neschválenému znění	vysoká	LegalDocumentSeedHostedService.cs:16-20; cs.md:5	→ R3
6	Přiřazený úklidník čte ConfirmationCode , CustomerEmail , DisplayOrderNumber hostovy objednávky — klíč anonymního CancelGuest	úklidník může zrušit hostovu objednávku jménem hosta	kritická	OrderMappers.cs: 250-275; GuestOrderAccess.cs:21-24	redakce ConfirmationCode pro úklidníka
7	Řádek Tenants nemá zapisovače: Tenant.Create volají jen testy, katalog admin příkazy má (CreateCountry , CreateService), provozní společnost ne	společnost nelze založit aplikační cestou	vysoká	grep -rn "Tenant.Create(" src --glob "*.cs" → 0 mimo testy; Tenant.cs:68-71	→ R2
8	Administrátor bez druhého faktoru: jen heslo, limit 10/min/IP a lockout 5×/15 min	ukradené heslo administrátora = celá provozní společnost	vysoká	rg -n "TwoFactor[Totp Mfa] src/ → 0; User.cs:14-17	2FA administrátora

#	mezera	proč	závažnost	citace	→ Rn
9	Cookie lišta u přihlášeného mapuje „analytics“ na <code>ConsentType.DataProcessing</code> a „marketing“ na <code>MarketingEmails</code> — klik na liště uděluje a odvolává souhlas se zpracováním údajů	souhlas odvolán bez vědomí zákazníka	vysoká	<code>consent-sync.service.ts:36-41</code>	→ R9
10	Hotovost: storno zapíše <code>FeeRate</code> na objednávku, refund běží jen pro <code>PaymentType.Card</code> a inkaso neexistuje; vybraná hotovost (<code>MarkCashCollected</code>) se nezapočítává proti odměně	poplatek se nevybere, tržbu drží úklidník	vysoká	<code>CustomerOrderCancellation.cs:90-95</code> ; <code>MarkCashCollected.cs:164</code>	→ R6

1. Bezpečnost

pravidlo	jedna věta	citace
S1 UserId is server-truth	Identita se čte z JWT claimu <code>NameIdentifier</code> , nikdy z těla; anonymní zápis jmenuje trh, server mapuje přes <code>SetTenantOverride</code>	<code>UserSessionProvider.cs:29-32</code> ; <code>OperatorTenantScopeBehavior.cs:53-69</code>
S2 Authorization on every endpoint	Výchozí politika <code>RequireAuthenticatedUser</code> na všech pěti hostech; test odmítne admin akci bez <code>[Permission]</code> mimo <code>AllowList</code>	<code>ServiceExtensions.cs:44-47</code> ; <code>AdminHostPermissionCoverageTests.cs:62-66</code>
S3 Resource-by-id ownership	<code>CanAccessOrderAsync</code> vrací true jen vlastníkovi, přiřazenému úklidníkovi nebo administrátorovi; zákazník čte přes <code>GetQueryableForOwner(userId)</code>	<code>OrderAccessService.cs:64-95</code> ; <code>OrderAccessService.cs:38-44</code>
S4 DTO leak prevention	<code>OrderPiiRedaction.RedactForBrowsingCleaner</code> nuluje jméno, e-mail, telefon, adresu, kód a instrukce pro prohlížejího úklidníka; test drží seznam <code>DetailBlanked</code>	<code>OrderPiiRedaction.cs:41-69</code> ; <code>OrderRedactionSurfaceTests.cs:34-43</code>

pravidlo	jedna věta	citace
S5 Rate limiting	Politiky <code>auth</code> 10/min IP, <code>interactive</code> 60/min, <code>webhook</code> 60/min, strop 20 000 anonymních/min; <code>KnownUncovered</code> prázdný	<code>RateLimitPolicies.cs:43-51</code> ; <code>RateLimitCoverageGuardTests.cs:142-144</code>
S6 Logging hygiene	<code>SafeBody</code> rediguje <code>SensitiveFieldRegex</code> a <code>ContactIdentityFieldRegex</code> ; cesty z <code>IsSensitivePath</code> potlačeny celé; test padne na neredigovaném DTO	<code>RequestLoggingMiddleware.cs:197-210</code> ; <code>RequestLogPiiSurfaceGuardTests.cs:98-103</code>
S7 Idempotency	Webhook Stripe: <code>HasProcessedAsync(stripeEvent.Id)</code> před účinky; refundace drží unikátní <code>RefundKey</code> , kolize 23505 = existující řádek	<code>HandlePaymentNotification.cs:158-173</code> ; <code>RefundService.cs:97-118</code>
S8 Tenant isolation	Globální EF filtr (<code>SetQueryFilter</code>) <code>e.TenantId == currentTenantId</code> ; <code>CommitAsync</code> razítkuje <code>TenantId</code> a odmítne zápis do zmražené společnosti	<code>CleansiaDbContext.cs:307-328</code> ; <code>CleansiaDbContext.cs:103-116</code>
S9 Migration & DTO-contract safety	Jediná migrace <code>Initial</code> ; test drží 48 razítkovaných tabulek (<code>StampedTables</code>) s FK <code>_Tenants_TenantId</code> a NOT NULL mimo dvě obálkové (<code>EnvelopeTables</code>); <code>TenantId</code> je cizí klíč do <code>Tenants</code>	<code>InitialMigrationTenantDdlTests.cs:24-25</code> ; <code>TenantIdRequiredModelTests.cs:15-16</code>
S10 Soft-delete / IsActive	Bez globálního filtru; čtenář filtruje sám, např. <code>Where(s => s.IsActive)</code> u uložených adres	<code>SavedAddressRepository.cs:18</code>
S11 Mobile session wipe	Android <code>clearSessionCaches()</code> při vynuceném 401; iOS <code>SessionScopedCacheRegistry.clearAll()</code> při odhlášení i zamítnutém refreshi	<code>AuthAuthenticator.kt:116-119</code> ; <code>SessionScopedCache.swift:19-31</code>
S12 Stored artifact disclosure	Roster <code>ExpectedIntakes</code> 17 upload tras, 15 z nich s pravidlem obsahu (dvě <code>BlobFileSize</code> only); <code>ImageMetadata.Scrub(byte[])</code> vybírá walker podle bytů, nic nedekóduje	<code>UploadIntakeRosterTests.cs:39-60</code> ; <code>ImageMetadata.cs:35-57</code>

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Přiřazený úklidník čte <code>ConfirmationCode</code> , <code>CustomerEmail</code> , <code>DisplayOrderNumber</code> hostovy objednávky — klíč anonymního <code>CancelGuest</code>	<code>OrderMappers.cs:250-275</code> ; <code>GuestOrderAccess.cs:21-24</code>	zákazník (host)	kritická	redakce <code>ConfirmationCode</code> pro úklidníka

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
GetOrderDetails vrací přiřazenému úklidníkovi (isEntitledToCustom erData) detail bez redakce; CancelGuest je [AllowAnonymous] , blokuje jen Cancelled/Completed /InProgress	GetOrderDetails.cs:15 0-158; OrderController.cs:18 -23	zákazník (host)	kritická	tatáž oprava
Administrátorské přeražení načte cílového úklidníka podle id a ověří jen EmployeeNotFound a EmployeeAlreadyAssig nedToOrder ; schválení (EmployeeNotApproved) , které vyžaduje převzetí, ani měnu úklidníka nechte	AdminReassignOrder. cs:74-87; TakeOrder.cs:80-85	zákazník / společnost	vysoká	kontrola schválení při přeražení
Administrátor bez druhého faktoru: jen heslo, limit 10/min/IP, lockout 5×/15 min	rg -n "TwoFactor Totp Mfa" src/ → 0; User.cs:14- 17	společnost	vysoká	2FA administrátora
Zákaznický a partnerský web neinstalují AddUserRevocationEnf orcement ani AddDeviceRevocationE nforcement ; jejich přístupový token 1 440 min platí i po resetu hesla	UserRevocationServic eExtensions.cs:13-21; appsettings.Productio n.json:20	zákazník / úklidník	střední	revokace na webových hostech
Deaktivace společnosti nezneplatní existující JWT úklidníků: IsDeactivated se čte jen v RefusalForAsync při přihlášení, výsledkem je CompanyDeactivated	CompanySignInGate. cs:27-41	společnost	střední	kontrola IsActive na každém tokenu

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Přiřazený úklidník má přístup k adrese a instrukcím i po dokončení bez časového limitu; <code>CanAccessOrderAsync</code> čte jen <code>AssignedEmployees</code>	<code>OrderAccessService.cs:88-94</code>	zákazník	střední	→ R8
Kód hosta je 6 hex znaků (16,7 mil. kombinací) v čitelné podobě na <code>Order.ConfirmationCode</code>	<code>OrderExtensions.cs:7;</code> <code>Order.cs:151</code>	zákazník (host)	nízká	→ R5
Registrace (<code>ExistingUserWithEmail</code>) i reset hesla (<code>NotExistingUserWithEmail</code>) prozrazují existenci e-mailu anonymnímu volajícímu	<code>Register.cs:42-44;</code> <code>RequestPasswordChange.cs:46-48</code>	zákazník	nízká	neutrální odpověď
DEV nasazení <code>Logging__LogLevel__Console__Information;</code> <code>RequestLoggingMiddleware</code> pod ni spadá, těla požadavků jdou do App Insights	<code>main.bicep:541;</code> <code>RequestLoggingMiddleware.cs:7-9</code>	všichni (DEV)	nízká	úroveň Warning i v DEV
Mapbox veřejný token <code>pk.eyJ</code> ve 4 commitech historie; ve stromu jen placeholder runbooku	<code>git log -S "pk.eyJ" --oneline → 4; AZURE-DEV-RUNBOOK.md:324</code>	společnost	nízká	rotace tokenu
Heslo lokálního Postgresu (<code>Host=localhost</code>) v trackovaném <code>local.settings.json</code>	<code>local.settings.json:27</code>	společnost	nízká	user secrets místo souboru

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Postgres v PRO má zapnutý veřejný endpoint (<code>publicNetworkAccess</code>) a v prod parametrech zakomentovaný <code>privateNetworkingEnabled</code> ; pravidlo <code>AllowAllAzureServicesAndResources</code> (0.0.0.0) je přepínač provozu uvnitř Azure	<code>postgres.bicep:144-151;</code> <code>weu.prod.bicepparam:64-68</code>	společnost	střední	privátní síť
Aplikace se připojuje jako administrátor serveru <code>cleansia_admin</code> s <code>Trust Server Certificate=true</code>	<code>derivedSecrets.bicep:48;</code> <code>weu.prod.bicepparam:74</code>	společnost	střední	aplikační role; ověření certifikátu
Bez auditu závislostí v CI (<code>npm audit / --vulnerable 0</code>); jen měsíční (<code>monthly</code>) security-updates pro <code>npm</code>	<code>rg -n "npm audit --vulnerable" .github/ → 0;</code> <code>dependabot.yml:26-31</code>	společnost	střední	audit závislostí v CI
API hosty ani zákaznický SSR nenastavují HSTS ani CSP; partnerský a admin SWA nesou <code>globalHeaders</code> <code>X-Content-Type-Options</code> , <code>X-Frame-Options</code> , <code>Referrer-Policy</code>	<code>rg -n "UseHsts Content-Security-Policy helmet" src --glob "*.cs" --glob "*.ts" → 0;</code> <code>staticwebapp.config.js</code> <code>on:12-15</code>	všichni	nízká	bezpečnostní hlavičky
Fotky interiéru se vydávají SAS odkazem (<code>GenerateSasUri</code>) s platností 1 h — přeposlatelný nositelský odkaz	<code>GetOrderPhotos.cs:129</code>	zákazník	nízká	→ R7
Bez virového skenu nahraných souborů; jen magic-byte <code>AcceptedByIntake</code>	<code>rg -in "clamav antivirus malware" src --glob "*.cs" → 0;</code> <code>SniffedContentType.cs:70-87</code>	společnost	nízká	AV sken uploadů

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
154 tenant-ignorujících čtení (105 v repozitářích) bez rosteru, např. <code>ExistsIgnoringTenantAsync</code> na objednavce; účinek se projeví u druhé provozní společnosti	<code>rg -n "IgnoreQueryFilters() GetQueryableIgnoringTenant()"</code> <code>src/Cleansia.Infra.Database</code> <code>src/Cleansia.Core.ApiServices</code> <code>src/Cleansia.Functions* → 154;</code> <code>OrderRepository.cs:244-248</code>	společnost	střední	roster tenant-ignorujících čtení
Hesla s 10 000 iteracemi (<code>LegacyIterations</code>) jsou platná vedle 600 000; povýšení umí jen <code>NeedsRehash</code> , které nikdo nevolá	<code>rg -n "NeedsRehash"</code> <code>src --glob "*.cs" → 1</code> deklarace + 1 test; <code>PasswordExtensions.cs:9-14</code>	zákazník / úklidník	nízká	povýšení hashe při přihlášení

2. Peníze a účetnictví

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Účtenka tiskne řádky jen za <code>SelectedServices</code> a <code>SelectedPackages</code> ; sleva a <code>ApplyExpressSurcharged</code> +20 % bez řádku; <code>SelectedExtras</code> jen <code>Slug</code> bez ceny	<code>ReceiptService.cs:395-404;</code> <code>OrderFactory.cs:129-130</code>	zákazník / společnost	vysoká	řádek slevy, příplatku a ceny doplňku
Řádkové ceny (<code>lineTotal</code>) jsou katalogové před slevou; objednávka nenese příznak expres (<code>AsChargedAgainst</code>); součet řádků <code>≠ Total</code>	<code>OrderFactory.cs:199-204;</code> <code>OrderFactory.cs:400-405</code>	zákazník / společnost	vysoká	příznak expres na objednávce

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Fiskální položky (<code>BuildFiscalLines</code>) jen služby a balíčky — bez extras, slev a příplatku; účinek je latentní, dokud je fiskalizace vypnutá	<code>ReceiptService.cs:275-299</code>	společnost	vysoká	fiskální položky = řádky dokladu
Hotovostní účtenka vzniká při vytvoření objednávky s <code>PaymentStatus: Pending</code> ; při dokončení se negeneruje znovu	<code>OrderPaymentDispatcher.cs:82-91</code> ; <code>ReceiptService.cs:410</code>	zákazník / společnost	vysoká	→ R6
Bez dobropisu při refundaci; refund je jen řádek <code>Refund</code> a stav objednávky	<code>rg -in "creditnote credit_note dobropis" src --glob "*.cs" → 0</code> ; <code>Refund.cs:81</code>	zákazník / společnost	vysoká	→ R1
Číslo účtenky <code>RCP-{rok}-{NNNN}</code> (<code>ReceiptNumberFormat</code>); při <code>FiscalEnforcementMode.None</code> vrací <code>FiscalSequenceScope.NoAnnualResetYear</code> — pořadí pokračuje přes roky	<code>ReceiptService.cs:60-64</code> ; <code>FiscalSequenceScope.cs:22-27</code>	společnost	střední	roční reset číselné řady
Doklad tiskne <code>VAT #</code> (DIČ <code>CZ12345678</code>) při <code>IsVatPayer = false</code> vedle „Nejsme plátcí DPH“	<code>DefaultReceiptLayoutBuilder.cs:161-162</code> ; <code>insert_seed_data.sql:1162-1163</code>	zákazník	střední	→ R2
Handler i validátor (<code>ConfigsExistAsync</code>) <code>CalculateOrderPay</code> zahrnují jen <code>SelectedServices</code> a čtou <code>SelectedPackages</code> prázdné — balíčková zakázka je bez balíčkové sazby	<code>CalculateOrderPay.cs:87-90</code> ; <code>CalculateOrderPay.cs:117-120</code>	úklidník	kritická	<code>Include(SelectedPackages)</code> v <code>CalculateOrderPay</code>

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Administrátorský přepis na <code>Completed</code> neposílá <code>CalculateOrderPayMes</code> sage — úklidník bez odměny	rg -n "CalculateOrderPayM essage(" src/ → jen <code>CompleteOrder.cs:34</code> 7; <code>AdminOverrideOrder</code> <code>Status.cs:141-147</code>	úklidník	vysoká	výpočet odměny i z override
<code>ResolveDispute</code> ignoruje selhání refund: spor <code>Resolved S</code> <code>RefundAmount</code> , peníze neodešly, výsledek Success	<code>ResolveDispute.cs:77-81</code> ; <code>ResolveDispute.cs:89-100</code>	zákazník	kritická	selhání refundu jako chyba příkazu
Chargeback i dvojí úhrada hostovy objednávky: <code>Dispute.UserId</code> required, <code>order.UserId ?? ""</code> → 23503 → webhook 500, Stripe opakuje	<code>HandlePaymentNotifi</code> <code>cation.cs:484-489</code> ; <code>DisputeEntityConfigur</code> <code>ation.cs:19-21</code>	společnost	vysoká	<code>Dispute.UserId</code> volitelné pro hosta
Prohraný chargeback jen zavře spor (<code>DisputeStatus.Close</code> <code>d</code>); <code>PaymentStatus</code> <code>Paid</code> se nemění, bez refund řádku, bez dopadu na odměnu	<code>HandlePaymentNotifi</code> <code>cation.cs:604-609</code> ; rg -n "OrderEmployeePay" src/Cleansia.Core.App Services/Features/Pay ments/HandlePayme ntNotification.cs → 0	společnost	vysoká	chargeback jako pohyb peněz
<code>Refund.StripeRefundI</code> <code>d</code> vždy null; id refund ze Stripe se neukládá	<code>RefundService.cs:170</code>	společnost	střední	uložení <code>StripeRefundId</code>
Storno u hotovosti zapisuje <code>FeeRate</code> 25/50 % přes <code>order.Cancel</code> ; refund běží jen pro <code>PaymentType.Card</code> ; inkaso poplatku neexistuje	<code>CustomerOrderCance</code> <code>llation.cs:49</code> ; <code>CustomerOrderCance</code> <code>llation.cs:90-95</code>	společnost	vysoká	→ R6

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Vybraná hotovost se nezapočítává proti odměně: složkami jsou <code>BasePay</code> , <code>ExtrasPay</code> , <code>ExpensesPay</code> , <code>BonusPay</code> , <code>DeductionPay</code> ; lhůta odvodu neexistuje	<code>rg -rn "CashCollected Settle dInCash" src/Cleansia.Core.App Services/Features/EmployeePayroll → 0; OrderEmployeePay.cs :38-46</code>	společnost	vysoká	→ R6
Plus člen plánu <code>PLUS_MONTHLY</code> (<code>freeWindow 4 h</code>) nikdy neplatí 25 %: <code>h >= freeWindow</code> zdarma, jinak <code>LastMinute 50 %</code>	<code>BookingPolicy.cs:344-351; insert_seed_data.sql:1804-1805</code>	zákazník	střední	→ R4
Fiskalizace vypnuta (<code>Fiscal:CzechEet2:Enabled=false</code>); <code>CzechEet2FiscalService</code> je stub, výchozí <code>NoOpFiscalService</code>	<code>appsettings.json:85; CzechEet2FiscalService.cs:8-12</code>	společnost	střední	→ R21
Fiskální resolver: <code>Country.IsoCode alpha-3 („CZE“)</code> vs <code>CountryCode „CZ“</code> — česká služba by nebyla nalezena	<code>ReceiptService.cs:162-163; CzechEet2FiscalService.cs:23</code>	společnost	střední	shoda kódu země
Jeden Stripe účet (<code>Stripe:SecretKey</code>) pro celý holding; per-společnost účet 0 — vyrovnání mezi společnostmi mimo software	<code>StripeClient.cs:34; rg -n "StripeAccount OnBehalfOf TransferData" src/Cleansia.Core.App Services src/Cleansia.Infra.Clients → 0</code>	společnost	střední	→ R2
Období lze znovu otevřít, není-li <code>Paid</code> ; faktura se generuje bez ohledu na stav období (<code>PayPeriodId</code> jen <code>ExistsAsync</code>)	<code>ReopenPayPeriod.cs:40-44; GenerateInvoice.cs:42-47</code>	úklidník / společnost	střední	brána stavu období

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Úprava částek faktury volá <code>UpdateAmounts</code> a končí — handler drží jediný <code>IEmployeeInvoiceRepo</code> <code>sitory</code> , vydané PDF nese starou částku; přegenerování je samostatný příkaz s <code>LanguageCode</code>	<code>UpdateInvoiceAmounts.cs:57;</code> <code>RegenerateInvoicePdf.cs:59</code>	úklidník	střední	→ R18
Hromadné mzdové sazby (<code>BulkCreateEmployeePayConfigs</code>) výchozí <code>Math.Round (ToEven);</code> výpočet mzdy (<code>decimal</code> součty) bez zaokrouhlení	<code>BulkCreateEmployeePayConfigs.cs:140-141;</code> <code>PayCalculatorExtensions.cs:44-52</code>	úklidník	nízká	jednotné zaokrouhlení
Seed <code>CompanyInfo</code> IČO <code>12345678</code> , DIČ <code>CZ12345678</code> , účet <code>123456789/0800</code> „REPLACE WITH ACTUAL" — tisknou se na účtenky (<code>RegistrationNumber</code> , <code>VatNumber</code>)	<code>insert_seed_data.sql:1</code> <code>158-1174;</code> <code>ReceiptService.cs:423-429</code>	zákazník / společnost	střední	→ R2
Swap plánu maže lokální <code>CancelledAt</code> , ale <code>SubscriptionUpdateOptions</code> <code>cancel_at_period_end</code> neruší; předplatné na Stripe dál končí	<code>UserMembership.cs:3</code> <code>02-304;</code> <code>StripeClient.cs:368-379</code>	zákazník	střední	zrušení <code>cancel_at_period_end</code> při swapu
„First-order" promokód (<code>maxRedemptionsPerUser</code> 1) nekontroluje, zda jde o první objednávku	<code>RequestPromoCodes.cs:84-91</code>	společnost	střední	kontrola první objednávky

3. Data a retence

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Adresy se deduplikují na <code>Street</code> , <code>City</code> , <code>ZipCode</code> , <code>CountryId</code> ; jeden řádek (<code>CustomerAddress</code>) sdílí celý dům	<code>AddressRepository.cs:9-16</code> ; <code>Order.cs:172-174</code>	zákazník	kritická	adresa per zákazník
Výmaz i retenční sweep volají <code>CustomerAddress.Anonymize()</code> na sdíleném řádku — přepíše adresu sousedům a jejich objednávkám	<code>GdprDeletionService.cs:393-396</code> ; <code>DataRetentionBackgroundService.cs:186-187</code>	zákazník	kritická	tatáž oprava
Změna telefonu (<code>GetOrdersByPhoneNumberAsync</code>) přepíše <code>CustomerPhone</code> všech objednávek se stejným číslem bez ohledu na <code>UserId</code>	<code>UpdateCurrentUser.cs:151-176</code> ; <code>OrderRepository.cs:13-17</code>	zákazník	vysoká	filtr <code>UserId</code> při přepisu
Retenční sweep anonymizuje jen objednávky s historií <code>Completed</code> ; zrušené a nesplněné se neanonymizují nikdy	<code>DataRetentionBackgroundService.cs:171-174</code>	zákazník	střední	sweep i pro zrušené
Fotky objednávek (<code>OrderPhoto</code>) retenční sweep neřeší; blob se maže jen při výmazu účtu	<code>rg -n "OrderPhoto photo" src\Cleansia.Core.AppServices\Features\DataRetention\DataRetentionBackgroundService.cs → 0</code> ; <code>GdprDeletionService.cs:368-381</code>	zákazník	střední	→ R7
<code>DeleteOrderPhoto</code> bez <code>[AuditAction]</code> a bez brány na stav zakázky (jen <code>AssignedEmployees.Anonymy</code>); smaže i fotografii „po“, na níž dokončení stálo	<code>DeleteOrderPhoto.cs:12</code> ; <code>DeleteOrderPhoto.cs:56-71</code>	zákazník / společnost	střední	→ R7

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Retenční okno má jen zákaznický audit (DeleteExpiredAsync podle CustomerAuditRetenti onYears); auditní tabulky administrátorů a úklidníků okno nemají	DataRetentionBackgr oundService.cs:319- 325	úklidník / společnost	nízká	okno pro auditní tabulky
Dokumenty úklidníka (PDF a Office) ImageMetadata nescrubuje; administrátor je stahuje (DownloadEmployeeDoc ument) i s metadaty autora	ImageMetadata.cs:28 -31; AdminEmployeeDocu mentController.cs:93- 99	úklidník	nízká	scrub dokumentů, nebo popis v DPA
Právní texty s bannerem Návrh – toto znění zatím neprošlo právní kontrolou seeduje LegalDocumentSeedHos tedService při každém startu v každém prostředí	LegalDocumentSeed HostedService.cs:16- 20; cs.md:5	společnost	vysoká	→ R3
Souhlas úklidníka s podmínkami odkazuje na žádný text (document : null); dokument LegalDocumentAudience.Employee neexistuje	RegisterEmployee.cs: 121-126; LegalSeedResource.cs :28	úklidník / společnost	vysoká	→ R3
Admin příkaz na novou verzi právního dokumentu neexistuje; AdminLegalController r jen čte (CanViewLegalDocumen ts)	rg -rn "ICommand<" src/Cleansia.Core.App Services/Features/Leg al → 0; AdminLegalController .cs:21	společnost	střední	→ R3

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Tick na objednávce neobnoví odvolaný souhlas: AssertedOrAlreadyCon sentedAsync ho přijme, OrderBookingEvidenc e zaznamená, UserConsents se nepíše	CreateOrder.cs:314- 317; CreateOrder.cs:1076- 1079	společnost	střední	→ R3
MarketingEmails bez čtenáře v AppServices; marketingový push čte jen Promo	grep -rn "MarketingEmails" src/Cleansia.Core.App Services → 0; SendSitewidePromoF anoutHandler.cs:104	zákazník	vysoká	→ R9
Fan-out kampaně nefiltruje profil: úklidník s Promo = true dostane zákaznický marketing	SendSitewidePromoF anoutHandler.cs:103- 109	úklidník	střední	filtr profilu ve fan- outu
Komentář IStripeConfig tvrdí, že GdprDeletionService maže Stripe Customer; kód volá jen RemoveForUserAsync na lokální id	IStripeConfig.cs:30; GdprDeletionService. cs:508-509	zákazník	střední	→ R9
RecordAsync ukládá surové tělo RawBody (fronta SendEmail nese adresu a živý kód) bez retence	DeadLetterStore.cs:20 -25; rg -n "DeadLetter" src/Cleansia.Core.App Services/Features/Dat aRetention/PruneOut box.cs → 0	zákazník / úklidník	střední	retenční okno DeadLetters
Export zákazníka obsahuje ResolutionNotes administrátora a IpAddress + UserAgent souhlasů	GdprExportService.cs: 176; GdprExportService.cs: 135-137	společnost	nízká	rozsah exportu

4. Odolnost a provoz

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Dead letters nikdo nečte: DeadLetter v admin kontrolerech 0, repozitář jen RemoveForSubjectAsync	rg -n "DeadLetter" src/Cleansia.Web.* / Controllers → 0; DeadLetterRepository.cs:20	společnost	střední	admin čtenář DeadLetters
Outbox po 10 pokusech (backoff 30 s × 2") označí Failed a dead-letteruje; jediná signalizace LogError	OutboxDrainerService.cs:79-86; OutboxDrainerConfig.cs:14-15	všichni	střední	alert na Failed
Alerty jen objemové: 5xx > 5 / 5 min, výjimky > 10	alerts.bicep:44-52	společnost	střední	alert na Failed a dead-letter
Jediným kanálem poplachu je emailReceivers jedné skupiny; poison fronta hlásí GreaterThan práh 0, tedy každou zprávu	alerts.bicep:66-72; queueAlerts.bicep:93-96	společnost	střední	SMS/pager kanál
Naplnění PRO: SeedDevelopmentData běží jen pod IsDevelopment a insert_seed_data.sql 1 proti PRO workflow odmítá; katalog admin příkazy má, řádek Tenants zapisovače nemá	CleansiaStartupBase.cs:242; execute-sql.yml:49-58	společnost	vysoká	→ R2
Nepříchod posádky zapisuje jediná cesta: kredit CleanerNoShow píše automatický běh CancelUnfilledOrders; host s prázdným UserId jej nedostane	CancelUnfilledOrders.cs:297-300; CancelUnfilledOrders.cs:276-279	zákazník	střední	→ R15
Jediný region weu → westeurope; prod parametry „AUTHORED, NOT DEPLOYED“	main.bicep:224-227; weu.prod.bicepparam:3	společnost	střední	nasazení PRO

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Záloha PRO 35 dní, geo-redundantní, HA ZoneRedundant ; postup obnovy v deploy/ 0	w eu.prod.bicepparam :56-58; rg -in "flexible-server restore point-in- time disaster" deploy/ → 0	společnost	střední	postup obnovy
Provozní runbook jen pro DEV (787 řádků); PRO posture 196 řádků bez incident/on-call postupu	AZURE-DEV- RUNBOOK.md:1; rg - in "incident on-call" deploy/AZURE- PROD-POSTURE.md → 0	společnost	střední	→ R10
Jediný poskytovatel bez záložního: SendGrid (e-mail), FCM (push, no-op bez tajemství), Stripe, Mapbox (geokódování)	SendGridClientFactor y.cs:16; MapboxGeocodingSe vice.cs:14-16	všichni	střední	záložní poskytovatel e-mailu
PeriodReminderBackgr oundService bez dedup razítka (čte GetQueryableIgnoring Tenant , nic nezapisuje); opakovaný běh pošle e-mail znovu	PeriodReminderBackgr oundService.cs:49-55	úklidník	střední	razítko odeslání
Bez události pro zákazníka: odchod úklidníka (DropOrder → SeatOpenedNotifier) i při OnTheWay ; storno administrátorem (CancelledBy.Admin) nese Reason , který nikam neodchází	DropOrder.cs:153- 172; AdminCancelOrder.cs :92-98	zákazník	vysoká	→ R18
Zamítnutá reklamace bez refundu nikoho neupozorní — oznámení jde jen při refund.IsSuccess ; zamítnutí úklidníka volá Reject a запиše ContractSnapshot , nic víc	ResolveDispute.cs:100 -104; RejectEmployee.cs:87 -95	zákazník / úklidník	střední	→ R18

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
ReportOrderIssue.Handler nikoho neupozorní (jen IOrderRepository a IOrderAccessService, žádný notifikátor)	ReportOrderIssue.cs:42-44	zákazník / společnost	střední	→ R10
E-mailly Confirmed/Started/Completed (EmailService, typ 6 bez seedu, bez per-locale defaults) jdou anglicky každému jazyku	EmailService.cs:375-390; grep -n "true, 6, "" sql-scripts/insert_seed_data.sql → 0	zákazník	střední	lokalizace e-mailů
Produkční Customer Mobile host posílá reset hesla na partner.cleansia.cz	appsettings.Production.json:30-31	zákazník	střední	oprava URL
Vývojová fixtura zakládá administrátora admin@cleansia.local se známým heslem Admin123!; čte se jen uvnitř IsDevelopment	insert_seed_data.sql:1890; CleansiaStartupBase.cs:223	společnost	nízká	jiné heslo mimo DEV

5. Mobilní aplikace

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Uvolnění místa (DropOrder) i žádost o zástup (RequestCover) server nese na partnerském webovém i mobilním hostu	OrderController.cs:240-271; OrderController.cs:285-317	úklidník	střední	→ R10

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Trasy DropOrder a RequestCover nevolá žádná aplikace: partnerský web 0, Android partner-app 0, iOS CleansiaPartner 0; žijí jen v generovaných artefaktech (partner-client.ts, partner-mobile-api.json)	rg -n "dropOrder requestCover DropOrder RequestCover" src/Cleansia.App/apps/cleansia-partner.app src/cleansia_android/partner-app/src/main src/cleansia_ios/CleansiaPartner/Sources → 0; partner-mobile-api.json:6620	úklidník	střední	→ R10
Prázdná nástěnka partner iOS (dash_no_jobs_yet_subtitle , L10n.Dashboard.noJobsYetSubtitle) říká „update your availability“; obrazovka dostupnosti neexistuje	Localizable.xcstrings:3624-3636; DashboardView.swift:323	úklidník	nízká	text bez odkazu na dostupnost
Google Pay (GooglePayConfiguration) v Android PaymentSheet ; Apple Pay na iOS 0	BookingBottomSheet.kt:597-606; rg -n "applePay PKPayment" src/cleansia_ios → 0	zákazník	nízká	Apple Pay v PaymentSheet
8 push událostí bez kategorie (getCategoryFor → null) nelze vypnout: OrderAssigned , ReminderSoon , InvoicePaid , EmployeeWeeklyLimits et ...	NotificationEventCatalog.cs:228-253	úklidník	nízká	→ R9
Kategorie NewJobsAvailable vypnutelná, ale žádný partnerský endpoint (UpdateNotificationPreferences) ji úklidníkovi nenastaví	NotificationEventCatalog.cs:249-251; rg -rn "UpdateNotificationPreferences" src/Cleansia.Web.Partner src/Cleansia.Web.Mobile.Partner → 0	úklidník	nízká	endpoint preferencí pro úklidníka

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Bez certificate pinningu, root/jailbreak detekce a biometrie (Android i iOS 0); tokeny v EncryptedSharedPreferences (Android), Keychain (iOS)	rg -n "CertificatePinner SecTrustEvaluate RootBeer Jailbreak BiometricPrompt LAContext" src/cleansia_android src/cleansia_ios → 0; TokenStore.kt:44-54	zákazník / úklidník	nízká	pinning; biometrický zámek
Android posílá souřadnice zařízení na api.mapbox.com s access_token, který je v APK jako MAPBOX_ACCESS_TOKEN	ReverseGeocodingService.kt:28-33; build.gradle.kts:54-57	zákazník / úklidník	střední	→ R9
Partnerská Android aplikace má allowBackup="true" (zákaznická false); ochranu nese jen výčet v backup_rules	AndroidManifest.xml: 33-37	úklidník	nízká	zákaz zálohy partnerské aplikace

6. Web

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Před souhlasem se načítají Google Fonts (fonts.googleapis.com, fonts.gstatic.com) — IP návštěvníka odchází Googlu	index.html:22-23; index.html:43-49	zákazník	střední	→ R9
Cookie „analytics“ se u přihlášeného mapuje na ConsentType.DataProcessing, „marketing“ na MarketingEmails — cookie klik uděluje/odvolává e-mailový souhlas	consent-sync.service.ts:36-41	zákazník	vysoká	→ R9

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Úklidník přihlášený v zákaznickém webu (JwtAudiences.Custom er přijímá každý profil) odmítnutím cookies volá withdrawConsent na DataProcessing	consent- sync.service.ts:46-50; TokenService.cs:93	úklidník	vysoká	→ R9
Žádný analytický tag neexistuje; banner (categories) přesto nabízí analytics/marketing/p references	rg -in "gtag googletagmana ger clarity hotjar" src/Cleansia.App/app s/cleansia.app → 0; cleansia-cookie- consent.component.t s:88-109	zákazník	nízká	→ R9
Souhlas anonymního návštěvníka jen v localStorage , bez serverového záznamu	cleansia-cookie- consent.component.t s:167-172	zákazník	nízká	→ R9
Okno rezervace 08:00–20:00 vynucují jen klienti (FIRST_WINDOW_HOUR , Android); server konstanty FirstWindowHour / Las tWindowHour nečte	booking- window.models.ts:11; BookingPolicy.cs:42- 43	společnost	střední	serverová validace okna
Web tvrdí, že stupeň nikdy neklesne ; RecomputeTier stupeň při odebrání bodů snižuje	cs.json:1344; LoyaltyAccount.cs:120	zákazník	střední	→ R17
Zákaznický web slibuje zkušební dobu textem trial_disclosure („Prvních {{days}} dní zdarma"), server ale plán s TrialPeriodDays odmítá	cs.json:1414; CreateMembershipPl an.cs:86-88	zákazník	nízká	odstranění trial copy

7. Dluh

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
OrderStatus.Pending bez producenta: 0 zápisů, a přesto je v ErasureBlockingStatu ses — drží výmaz účtu	rg -n "OrderStatus.Pending " src --glob "*.cs" → 0 zápisů mimo deklaraci; GdprDeletionService. cs:220-223	společnost	nízká	odstranění členu
PaymentStatus.Disput ed a RefundStatus.Failed bez zapisovatele	grep -rn "PaymentStatus.Dispu ted RefundStatus.Faile d" src --glob "*.cs" → 0 zápisů mimo testy; PaymentStatus.cs:12	společnost	nízká	odstranění, nebo zapisovač
ContractStatus.Activ e a Terminated bez zapisovače; čtenáři je rozlišují (PeriodReminderBackg roundService)	ContractStatus.cs:9- 10; PeriodReminderBackg roundService.cs:83	společnost	nízká	odstranění, nebo zapisovač
IsFirstTimeCustomer = false natvrdo — OopsWindowMinutesFir stTime 60 min se nikdy neuplatní	CancellationAssessor. cs:32; BookingPolicy.cs:82	zákazník	nízká	→ R4
order.confirmed v katalogu, feed sadě i APNs mapě bez producenta	NotificationEventCata log.cs:11-12; grep -rn "OrderConfirmed" src/Cleansia.Core.App Services → 0	společnost	nízká	odstranění události
Operátora trhu nastavuje jen AssignOperator bez produkčního volajícího; OperatorTenantId tak zapisuje pouze seed	grep -rn "AssignOperator(" src --glob "*.cs" → 0 mimo testy; CountryConfiguration .cs:193-195	společnost	nízká	→ R2
Order.SetTravelDista nce bez produkčního volajícího; DistanceRatePerKm nikdy neplatí	Order.cs:762; PayCalculatorExtensio ns.cs:15	úklidník	nízká	→ R6

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Trial mrtvý kód: sloupce TrialPeriodDays , TrialEndsAtUtc a trial větve Stripe klienta	20260920204705_Initi al.cs:149; StripeClient.cs:331- 334	společnost	nízká	odstranění trial kódu
i18n bez čtenáře: components.availabil ity 22 klíčů × 5 jazyků; partnerská návodová popisuje Pending jako „legacy state"	git grep "components.availabil ity" -- src/Cleansia.App -- include=.ts -- include=.html → 0; en.json:1724-1725	společnost	nízká	odstranění klíčů
iOS CleansiaCore 21 chybových klíčů bez emitujícího hosta (error.order.cancell ation_window_closed ...); Android 26 (error_referral_self _referral ...)	git grep -F "order.cancellation_wi ndow_closed" -- 'src/*.cs' → 0; Localizable.xcstrings:3 362	společnost	nízká	odstranění klíčů
Zastaralé komentáře: RecurringBookingTemp late „No UI exists today" (endpoint Create existuje); CancellationPolicyRes olver „no Plus product live" (plány seedovány)	RecurringBookingTem plate.cs:14-15; CancellationPolicyRes olver.cs:10-12	společnost	nízká	oprava komentářů
Komentář ConfirmRecurringOrde r „webhook flips it to Confirmed" — webhook zapisuje jen Paid; Order.MembershipDisc ountAmount tvrdí výlučnost slev, DiscountResolution je skládá	ConfirmRecurringOrd er.cs:273-275; Order.cs:327-333	společnost	nízká	oprava komentářů
Název společnosti na 3 místech: Tenants.Name „Cleansia CZ s.r.o.", CompanyInfo.LegalNam e „Cleansia s.r.o.", patička webu a e- mailů „Cleansia s.r.o."	insert_seed_data.sql:6 3-64; insert_seed_data.sql:1 147-1158	zákazník / společnost	střední	→ R2